

Security Assessment



Item 28 Internal Report

November 2026

Prepared for ether.fi





Disclaimer

This document is intended for **internal** use only.





Initial Commit Hash	Final Commit Hash
edaf4d0a	b35221b7

Protocol Scope

- src/etherfi/TreasuryFeeSplitter.sol

Low Severity Issues

L-01: Anyone can sweep reinvested treasury funds as revenue

Severity: Low	Impact: Low	Likelihood: Low
Files: src/etherfi/TreasuryFeeSplitter.sol	Status: Fixed	

Description: splitRevenue() withdraws the whole TreasurySpoke position on the Hub and splits it between the two recipients. The Hub keeps fee shares and supplied shares in the same addedShares balance, so the splitter has no way to know which part is revenue, instead treating all of it as fees.

The NatSpec for executeOnTreasury lists supplySkimmed as a supported use. Therefore, after the timelock supplies treasury capital back into the Hub, any account can call splitRevenue() and send that capital to the recipients.

Recommendations: Restrict splitRevenue() to the owner or to a keeper role, so that the treasury decides when to split and what stays invested.

Customer Response: Fixed in commit b35221b7

Fix Review: Fixed

Informational Issues

I-01. Renouncing splitter or TreasurySpoke ownership can irreversibly disable administration

Description: The splitter inherits renounceOwnership without disabling it, and its owner-only executeOnTreasury can forward arbitrary calldata to the TreasurySpoke. Renouncing splitter ownership permanently removes owner-mediated administration and prevents transferring ownership again. Forwarding renounceOwnership() to the TreasurySpoke sets its owner to the zero address; its onlyOwner operations, including withdrawals, then become unavailable, causing splitRevenue to fail and fee balances to remain stranded.

Recommendation: Override the splitter's renounceOwnership to revert and reject renounceOwnership() calldata in executeOnTreasury.

Customer Response: Fixed in commit b35221b7

Fix Review: Fixed

I-02. A blocked or reverting immutable ERC-20 recipient can prevent token splitting

Description: The recipients are immutable, and splitRevenue transfers each share using safeTransfer. If either recipient is blacklisted by the token or rejects the transfer, the split reverts, preventing the other recipient from receiving its share as well.

Recommendation: Consider allowing the recipient addresses to be updated.

Customer Response: Fixed in commit b35221b7

Fix Review: Fixed

I-03. Implement Upgradeability for TreasuryFeeSplitter to Align with TreasurySpoke

Description: The current TreasuryFeeSplitter implementation is immutable, creating an architectural mismatch with the upgradeable TreasurySpoke.

If the TreasurySpoke interfaces, withdrawal mechanisms, or Hub interaction flows are altered, an immutable splitter risks permanent integration breakage and trapped revenue. Furthermore, replacing an immutable contract would require coordinating complex actions to update destination addresses and manually rescue undistributed yields.

Adopting an upgradeable pattern also gives Ether.fi the flexibility to adapt fee-split ratios, introduce new beneficiaries, or patch unforeseen logic flaws without redeployment.

Recommendation: It is recommended to convert TreasuryFeeSplitter into an upgradeable proxy (such as UUPS) using an initialize function, with upgrade authorization strictly restricted to Ether.fi governance.

Customer's response: Acknowledged

Fix review: Acknowledged





Disclaimer

Even though we hope this information is helpful, we provide no warranty of any kind, explicit or implied. The contents of this report should not be construed as a complete guarantee that the contract is secure in all dimensions. In no event shall Certora or any of its employees be liable for any claim, damages, or other liability, whether in an action of contract, tort, or otherwise, arising from, out of, or in connection with the results reported here.

About Certora

Certora is a Web3 security company that provides industry-leading formal verification tools and smart contract audits. Certora's flagship security product, Certora Prover, is a unique SaaS product that automatically locates even the most rare & hard-to-find bugs on your smart contracts or mathematically proves their absence. The Certora Prover plugs into your standard deployment pipeline. It is helpful for smart contract developers and security researchers during auditing and bug bounties.

Certora also provides services such as auditing, formal verification projects, and incident response.